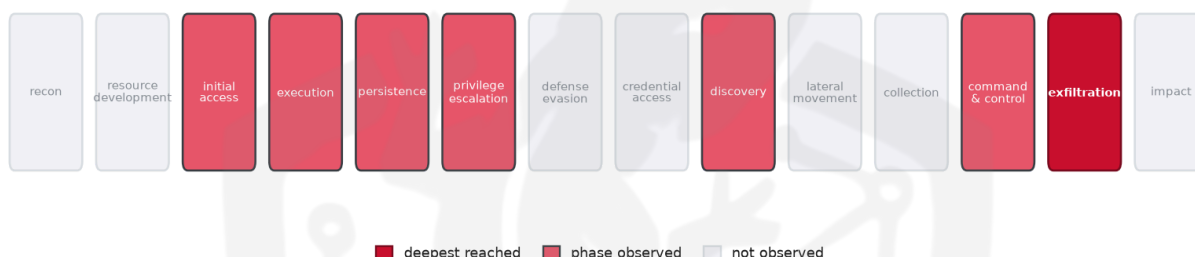


THREAT REPORT: KIMSUKY DEPLOYS AI AGENT “OPENCODE” TO CREATE DECOYS IN EVOLVING GITHUB PAT-BASED LNK ATTACKS

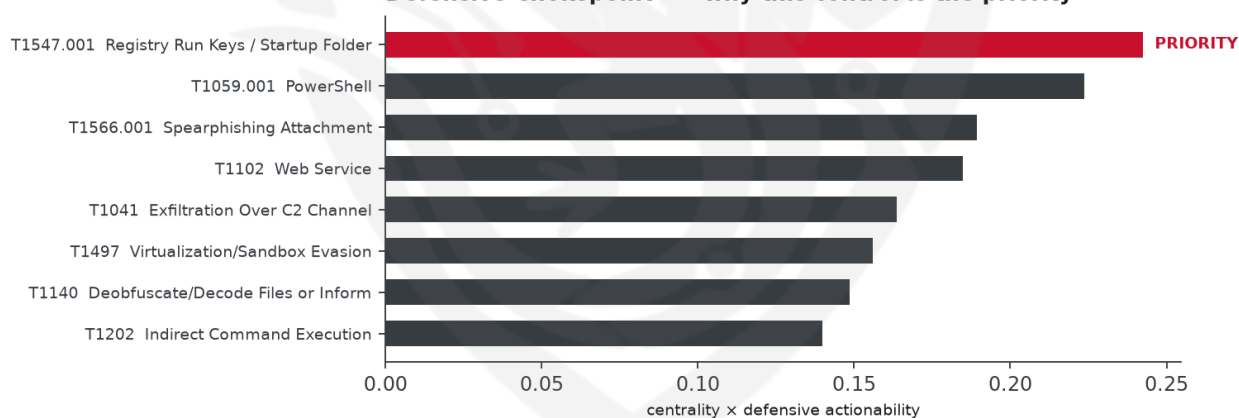
Visual Summary

Kill-Chain Reach — Critical (deepest phase reached: exfiltration)



How far down the attack chain this campaign reached; deepest phase in crimson.

Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

Summary

Kimsuky is leveraging an AI-driven tool named **opencode** to generate decoy files that support its GitHub personal-access-token (PAT)-based LNK campaigns. The activity targets organizations in the finance and government sectors. Although no specific malware family or CVE is identified, the threat chain culminates in persistence via Windows startup mechanisms. **Priority should be given to auditing Windows Startup folders and Run/RunOnce registry keys for unauthorized entries; alert on .lnk or script creation in Startup by browser/email temporary paths.**

Threat Overview

The source attributes this activity to **Kimsuky**. No malware family or CVE is disclosed in the report. The campaign focuses on victims in the finance and government sectors, employing a range of ATT&CK techniques to deliver and maintain malicious LNK files.

Attack Chain and Priority Control

The observed sequence begins with spearphishing attachments (T1566.001) that deliver malicious LNK files (T1204.002). The LNK payload triggers indirect command execution (T1202) and PowerShell scripts (T1059.001), which create scheduled tasks (T1053.005) and manipulate registry run keys and startup folders to achieve persistence. Additional steps include system information discovery (T1082), file and directory discovery (T1083), and exfiltration over the C2 channel (T1041).

Priority technique: T1547.001 Registry Run Keys / Startup Folder

Concrete control: Audit Windows Startup folders and Run/RunOnce registry keys for unauthorized entries; alert on .lnk or script creation in Startup by browser/email temp paths.

Infrastructure and Corroboration

The analysis did not identify any hosting providers or autonomous system numbers associated with this activity. Abuse.ch reports no corroborated malware families, and AbuseIPDB did not flag any indicators with a confidence level of 80 % or higher.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1053.005 Scheduled Task
- T1036.005 Match Legitimate Resource Name or Location
- T1204.002 Malicious File
- T1566.001 Spearphishing Attachment
- T1082 System Information Discovery
- T1070.003 Clear Command History
- T1202 Indirect Command Execution
- T1140 Deobfuscate/Decode Files or Information
- T1083 File and Directory Discovery
- T1497 Virtualization/Sandbox Evasion
- T1102 Web Service
- T1041 Exfiltration Over C2 Channel
- T1059.001 PowerShell
- T1547.001 Registry Run Keys / Startup Folder
- T1027 Obfuscated Files or Information
- T1027.002 Software Packing

- T1071.001 Web Protocols
- T1105 Ingress Tool Transfer
- T1564.001 Hidden Files and Directories

Analytical Scores

- Priority technique (graph chokepoint): T1547.001 Registry Run Keys / Startup Folder (centrality 0.2553).
- Operational risk: Critical (score 0.968, reaches exfiltration).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.5367; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
RedCurl	0.5367
Confucius	0.5357
Nomadic Octopus	0.5128
Higaisa	0.5017
Windshift	0.5015

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator
Hash	f1bd5817678f498966f033f61b617dee5c8e81191901fea7c4a89146bfe91091
Hash	10780939962b54addc9d31f57d80edfc
Hash	1523a2fcc901965ab4568d9fe829e4af
Hash	500e0bc0d7579fb338912770964076fe

Type	Indicator
Hash	685bfc6b2c29fbc16cfad908894add55
Hash	7a53089053b1381742856a5cf2b95f8b
Hash	8db2f20b719dcb7029d6296505622093
Hash	900e832c10d851bbdef3fb191a15db0e
Hash	a2015665a3e18bf0ef86e3931245c7e6
Hash	bb88940e915b11f6330b7446f6037f5b
Hash	ce5932b88f879f26006df81f2fa7667e
Hash	d0894d4626aae0f96d6b84ca3bb71a36
Hash	e50f2ae7fb03675a1ef58b1cf9cda6d1
Hash	f648bdd3c2cd902e239149de86d43e8f
Hash	441b709b1a57353a7b127d9a35b5002eee7e6efb
Hash	f72bd8bde005b8646d64f6a516407b6f9d2c680a
Hash	8d0aad27440fb29f9ab5f1af0f7977ed332d945d4bbeb7af0a96e07ac24eaaff

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1547.001 Registry Run Keys / Startup Folder (persistence)
- **Observed here:** T1547.001 Registry Run Keys / Startup Folder was the persistence control point here; the pivot is drawn from Kimsuky's own documented ATT&CK repertoire.
- **Projected pivot:** T1543 Create or Modify System Process (persistence)
- **Basis:** documented in Kimsuky's own ATT&CK repertoire, and disproportionately paired with Registry Run Keys / Startup Folder across tracked groups (lift 1.8, ~1.8x base rate). Their move, not a generic one.

With T1547.001 Registry Run Keys / Startup Folder blocked, Kimsuky could preserve the same objective by pivoting to T1543 Create or Modify System Process, a technique from Kimsuky's documented repertoire. Defensive countermeasure: Restrict service/daemon creation to admins; monitor service and driver installs.

Also plausible (same tactic): T1098 Account Manipulation (n=12, lift 2.0), T1112 Modify Registry (n=17, lift 1.7)

Detection and hardening for the pivot (T1543 Create or Modify System Process)

- **Telemetry:** Windows Security / System log; Sysmon
- **Detect:**
 - System 7045 (new service installed); Security 4697 (service installed)
 - Sysmon 1 for sc.exe / services created; unusual ImagePath or user-context services
 - Registry writes under HKLM\SYSTEM\CurrentControlSet\Services
- **Harden:**
 - Restrict service creation to admins; application control on service binaries
 - Baseline installed services and alert on new/anomalous ones
- **MITRE:** M1047 Audit, M1028 Operating System Configuration, M1026 Privileged Account Management · DS0019 Service, DS0024 Windows Registry, DS0009 Process

